Security Technologies

Intrusion Detection/Prevention

Chapter 7

Principles of Information Security, Michael E., Whitman & Mattord, H. J., Cengage Learning, 2017.

Learning Objective

- Identify and describe the categories and operating models of intrusion detection and prevention systems
- Define and describe honeypots, honeynets, and padded cell systems
- Explain the various methods of access control, including the use of biometric access mechanism

Intrusion

- An intrusion occurs when an attacker attempts to gain entry into or disrupt the normal operations of an information system, almost always with the intent to do harm.

Intrusion Detection/Prevention Systems

- Intrusion prevention consists of activities that deter an intrusion. Prevention activities are:

1. Writing and implementing good enterprise information security policy
2. Planning and executing effective information security programs
3. Installing and testing technology-based information security countermeasures (such as firewalls and intrusion detection systems)
4. Conducting and measuring the effectiveness of employee training and awareness activities.

Intrusion Detection System

- Intrusion detection consists of procedures and systems that identify system intrusions.
- Intrusion reaction encompasses the actions an organization takes when an intrusion is detected.
- These actions seek to limit the loss from an intrusion and return operations to a normal state as rapidly as possible.
- Intrusion correction activities finalize the restoration of operations to a normal state and seek to identify the source and method of the intrusion in order to ensure that the same type of attack cannot occur again—thus reinitiating intrusion prevention.

Intrusion Detection System

- Information security intrusion detection systems (IDSs) became commercially available in the late 1990s.
- An IDS works like a burglar alarm in that it detects a violation (some system activity analogous to an opened or broken window) and activates an alarm.
- This alarm can be audible and/or visual (producing noise and lights, respectively), or it can be silent (an e-mail message or pager alert).

Intrusion Detection and Prevention System (IDPS)

- A current extension of IDS technology is the intrusion prevention system (IPS), which can detect an intrusion and also prevent that intrusion from successfully attacking the organization by means of an active response.
- Combined term intrusion detection and prevention system (IDPS) is generally used to describe current anti-intrusion technologies.

Why use IDPS?

- According to the NIST documentation on industry best practices, there are several compelling reasons to acquire and use an IDPS:

1. To prevent problem behaviors by increasing the perceived risk of discovery and punishment for those who would attack or otherwise abuse the system.
2. To detect attacks and other security violations that are not prevented by other security measures.
3. To document the existing threat to an organization.
4. To act as quality control for security design and administration, especially in large and complex enterprises.
5. To provide useful information about intrusions that do take place, allowing improved diagnosis, recovery, and correction of causative factors.

IDPS Terminologies

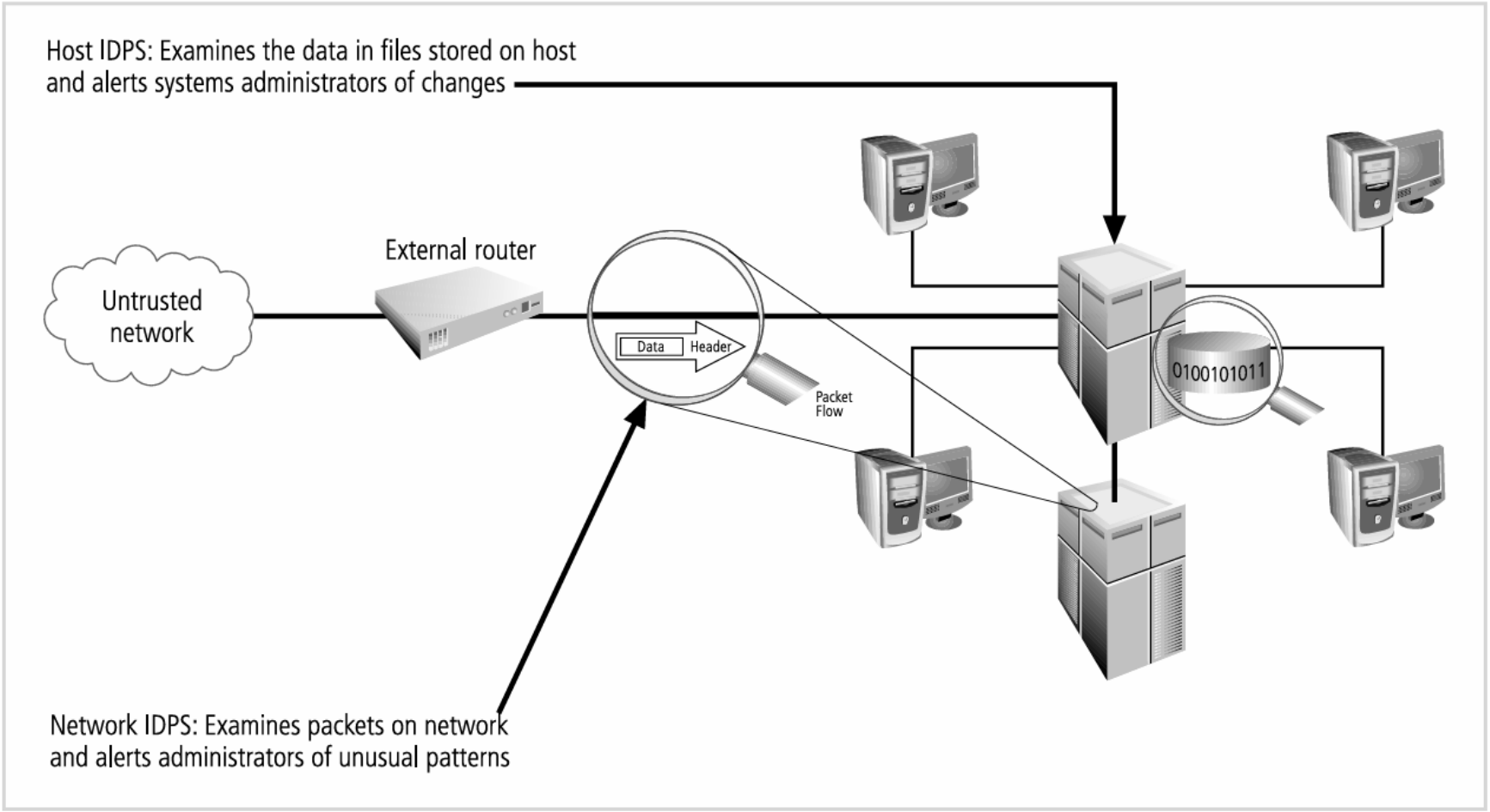
- Alert or alarm: Indication that a system has just been attacked or is under attack. IDPS alerts and alarms take the form of audible signals, e-mail messages, pager notifications, or pop-up windows.
- Evasion: The process by which attackers change the format and/or timing of their activities to avoid being detected by the IDPS.
- False attack stimulus: An event that triggers an alarm when no actual attack is in progress.
- Scenarios that test the configuration of IDPSs may use false attack stimuli to determine if the IDPSs can distinguish between these stimuli and real attacks.

IDPS Terminologies

- False positive: An alert or alarm that occurs in the absence of an actual attack.
- A false positive can sometimes be produced when an IDPS mistakes normal system activity for an attack.
- False positives tend to make users insensitive to alarms and thus reduce their reactivity to actual intrusion events.
- Site policy: The rules and configuration guidelines governing the implementation and operation of IDPSs within the organization.
- True attack stimulus: An event that triggers alarms and causes an IDPS to react as if a real attack is in progress.
- Confidence value: The measure of an IDPS's ability to correctly detect and identify certain types of attacks.

Types of IDPS

- Network based systems
- Host based system
- A network-based IDPS is focused on protecting network information assets.
- Two specialized subtypes of network-based IDPS are:
  - Wireless IDPS
  - Network behavior analysis (NBA) IDPS.
- The wireless IDPS focuses on wireless networks, as the name indicates, while the NBA IDPS examines traffic flow on a network in an attempt to recognize abnormal patterns like DDoS, malware, and policy violations.


Host IDPS: Examines the data in files stored on host and alerts systems administrators of changes
External router
Untrusted network
Data
Header
Packet Flow
0100101011
Network IDPS: Examines packets on network and alerts administrators of unusual patterns

Network Based IDPS

- A network-based IDPS (NIDPS) resides on a computer or appliance connected to a organization's network and monitors network traffic on that network segment, looking for indications of ongoing or successful attacks.
- Identifies activity that it is programmed to recognize as an attack, it responds by sending notifications to administrators.
- When examining incoming packets, an NIDPS looks for patterns within network traffic such as large collections of related items of a certain type—which could indicate that a denial-of-service attack

Network Behavior Analysis System

- NBA systems examine network traffic in order to identify problems related to the flow of traffic.
- Typical flow data particularly relevant to intrusion detection and prevention includes:

1. Source and destination IP addresses
2. Source and destination TCP or UDP ports or ICMP types and codes
3. Number of packets and bytes transmitted in the session
4. Starting and ending timestamps for the session

Host Based IDPS

- A host-based IDPS (HIDPS) resides on a particular computer or server, known as the host, and monitors activity only on that system.
- HIDPSs are also known as system integrity verifiers.
- Monitor the status of key system files and detect when an intruder creates, modifies, or deletes monitored files.

IDPS Detection Method

- Signature Based
- Statistical Anomaly-Based IDPS
- Stateful Protocol Analysis IDPS
- Log file monitors

Signature-Based IDPS

- Sometimes called a knowledge-based IDPS or a misuse-detection IDPS.
- Examines network traffic in search of patterns that match known signatures—that is, preconfigured, predetermined attack patterns.
- Signature based IDPS technology is widely used because many attacks have clear and distinct signatures,
- for example: DoS DDoS attack, footprinting and fingerprinting activities use ICMP, DNS querying, and e-mail routing analysis;

Statistical Anomaly-Based IDPS

- Behavior-based IDPS collects statistical summaries by observing traffic that is known to be normal.
- This normal period of evaluation establishes a performance baseline.
- Once the base line is established, the stat IDPS periodically samples network activity and, using statistical methods, compares the sampled network activity to this baseline.
- When the measured activity is outside the baseline parameters—exceeding what is called the clipping level—the IDPS sends an alert to the administrator.
- The baseline data can include variables such as host memory or CPU usage, network packet types, and packet quantities.

Stateful protocol analysis (SPA

- is a process of comparing predetermined profiles of generally accepted definitions of benign activity for each protocol state against observed events to identify deviations.
- Stateful protocol analysis relies on vendor-developed universal profiles that specify how particular protocols should and should not be used.
- Essentially, the IDPS knows how a protocol, such as FTP, is supposed to work, and therefore can detect anomalous behavior.
- By storing relevant data detected in a session and then using that data to identify intrusions that involve multiple requests and responses, the IDPS can better detect specialized, multisession attacks.
- sometimes called deep packet inspection because SPA closely examines packets at the application layer for information that indicates a possible intrusion.

Log File Monitors

- Reviews the log files generated by servers, network devices, and even other IDPSs, looking for patterns and signatures that may indicate that an attack or intrusion is in process or has already occurred.
- While an individual host IDPS can only examine the activity in one system, the LFM is able to look at multiple log files from a number of different systems.
- The patterns that signify an attack can be subtle and difficult to distinguish when one system is examined in isolation, but they may be more identifiable when the events recorded for the entire network and each of the systems in it can be viewed as a whole.

Honeypot, Honeynets and padded cell system

- Powerful security tools that go beyond routine intrusion detection is known variously as honeypots, honeynets, or padded cell systems.
- Honeypots are decoy systems designed to lure potential attackers away from critical systems.
- When a collection of honeypots connects several honeypot systems on a subnet, it may be called a honeynet.
- A honey pot system contains pseudo-services that emulate well-known services, but is configured in ways that make it look vulnerable to attacks.
- This combination is meant to lure potential attackers into committing an attack, thereby revealing themselves.
- The idea being that once organizations have detected these attackers, they can better defend their networks against future attacks targeting real assets.

Honeypot, Honeynets and padded cell system

- In sum, honeypots are designed to do the following:

1. Divert an attacker from critical systems
2. Collect information about the attacker's activity
3. Encourage the attacker to stay on the system long enough for administrators to document the event and, perhaps, respond

Cont…

- IDPS researchers have used padded cell and honeypot systems since the late 1980s, but until recently no commercial versions of these products were available.
- It is important to seek guidance from legal counsel before deciding to use either of these systems in your operational environment, since using an attractant and then launching a back hack or counterstrike might be illegal, and could make the organization vulnerable to a lawsuit or criminal complaint.

Honeypot, Honeynets and padded cell system

- Disadvantages:

1. The legal implications of using such devices are not well understood.
2. Honeypots and padded cells have not yet been shown to be generally useful security technologies.
3. An expert attacker, once diverted into a decoy system, may become angry and launch a more aggressive attack against an organization's systems.
4. Administrators and security managers need a high level of expertise to use these systems.

Questions